



INFORMATION SECURITY GOVERNANCE AND RISK MANAGEMENT

MECR1023

SECTION 52

LECTURER

ASSOCIATE PROF DR NORAFIDA ITHNIN

SELF REFLECTION 03 (CHAPTER 6)

NAME	MATRIC NO.
KEERTENNAH DEVI A/P PONNAMBALAM	MEC254026
SHWETHA A/P C.RAVICHANDRAN	MEC254010

Assume that you are a Security Manager:

- a) Choose TWO policies from the same Policy Category as listed in the SANS's web
 - Access Management Policy and Identity Management Policy from Identity and Access
- b) Discuss what are the differences between the two policies

Dimension	Identity Management Policy	Access Management Policy
Objective	Determines and administers the existence, uniqueness, and legitimacy of digital identities in the organisation, primarily ensuring that each account is assigned to, and only remains, to a real and valid "authorised user" for the appropriate time period.	Oversees the interactions of authorised identities with the systems, applications and data. The focus is less on the existence of an identity, and more on whether the access rights assigned to that identity are adequate and suitably managed.
Question addressed	"Who is the user, and should this identity exist at this point in time?"	"What is this user allowed to access, and under what conditions?"
Position in IAM lifecycle	Works at the first and last stages of the IAM life cycle which includes the practice of identity creation, maintenance, suspension, and termination.	Works after identity is created; focuses on continuous access provision, audit, adjusting, and system removing.
Dependency on HR processes	Strongly dependent with Human Resources functions including the HR programs and the HRIS. Employment status automatically initiates provisioning and de-provisioning.	Independent from HR systems. Rather relies on organizational role definitions and access governance methodologies after identity exists.
Account provisioning approach	Employs automated provisioning and de-provisioning based on HR events like entry, role modification, and exit.	Utilizes role and ACL, generally with approval and documented access requests possibly required rather than automatically generated access.
Account de-provisioning focus	Focuses on the issue of promptly removing identities when users exit, or do not use the system anymore, to eliminate orphaned or ghost accounts.	Removal or modification of access rights are key, less on the identity which remains active.
Identity uniqueness controls	Contributes to system accountability by prohibiting shared accounts, concurrent logins, and reuse of account names within a set time limit.	Does not directly address identity uniqueness; already assumes identities are unique and legitimate.
Authentication controls	Emphasises more on authentication methods like password policies,	Minimal focus on authentication, assumes

	encryption, salting and hashing techniques, account lockout policies, multi-factor authentication, and safe methods of credential distribution, among others.	authentication controls are elsewhere and focuses on authorization instead.
Authorization controls	Very minimal direct authorizations and is more to ensuring the right identity management is done rather than what is available for access.	Strong authorization controls via ACLs, role based access control, least privilege and segregation of duties.
Role definition	Roles are implicit and mostly auto-assigned based on some HR attributes or some identity attributes.	Roles are defined, documented, delineated, and reviewed and that documentation is used for access decisions.
Least privilege enforcement	Indirect, valid identification of the individual is done but there is no fine control for the permission scope.	Separation of duties for fraud and misuse of access is clearly articulated.
Segregation of duties	Not an area of great focus whereby emphasis is more on ensuring the identity is valid than on potential role conflicts.	Through applications, operating systems, databases, code repositories, business systems via ACLs.
Technical systems governed	Identity Providers, SSO's, authentication services, and identity management platforms.	Applications, operating systems, databases, code repositories, and business systems through ACLs.
Monitoring and logging focus	Engagement patterns, like failed authentication attempts, access attempts on inactive/deactivated accounts, and suspicious activity unusual for the user are monitored.	Focus is on access-related activities (changes in roles, group memberships, and ACL configurations).
Risk types primarily mitigated	Identity compromise at the identity level, insiders, orphaned accounts, shared credentials, and unauthorized identities.	Especially with regards to excessive privileges, unauthorized data access, privilege escalation, and access misuse in systems.
Impact of failure	Results in a lack of justification for the account, delays in revoking access, and a lack of responsibility for actions taken using stale/compromised lack of identities.	Results in abuse of access, heightened risk of fraudulent activity, violations of regulations, unauthorized access, and/or breaches of sensitive data.
Audit relevance	Strongly supports audits in the context of identity and access management.	Fosters positive consequences of access rights review audits, segregation of duties, and least privilege enforcement.
Overall governance role	Forms the necessary foundation of IAM and most importantly ensures that only valid identities are allowed in and to stay in the environment.	Serves as the control layer, ensuring that real identities do not go beyond their permitted limits.

Summary:

Despite the fact both policies fall in the same identity and access management domain, the Identity Management Policy deals with the creation, sustainment, and discontinuation of user identities from an organization and HR processes perspective for legitimacy and accountability, whereas the Access Management Policy deals with the management of which verified identities have (or do not have) access to systems, applications, and data according to roles and responsibilities, as well as the principle of least-privilege.

- c) Choose ONE from the two chosen policies and change the policy document to make it such a POLICY you make for your OWN ORGANIZATION
- Identity Management Policy



Identity Management Policy

(Last Updated November 2025)

Purpose

At National Oilwell Varco, our Identity Management Policy is designed to do more than just manage passwords. It is about establishing a secure framework that empowers our workforce while strictly controlling access to our critical systems. We aim to create a seamless environment where user identities are created, maintained, and retired efficiently, ensuring that the right people have the right access at the right time. By embedding robust identity verifications into our daily operations, we are actively working to reduce the risks of unauthorized entry and insider threats that could compromise not only our proprietary data but also the safety of our physical rig assets. Ultimately, through strong authentication and regular reviews, we strive to protect the integrity of our technology, maintain compliance with industry regulations, and uphold the deep trust our customers and stakeholders place in NOV to operate safely and securely. To maintain the high standards set forth in the NOV Trust Center, align identity practices with ISO 27001 certification and fulfilling our promise of data stewardship to our energy sector customers.

Scope

This Identity Management Policy applies to all NOV employees, contractors, supply chain partners, and stakeholders. It covers the full lifecycle of identity management from the moment a user is provisioned with access to our IT infrastructure and Operational Technology (OT) networks, to the day those credentials are retired. Whether you are accessing corporate applications, cloud resources, or critical control systems on a remote drilling rig, this policy governs the credentials you use. It sets the standard for how we verify identities, enforce role-based access, and utilize tools like Multi-Factor Authentication (MFA) to keep our environment secure. Everyone, from system administrators managing the backend to the end-users logging in daily, plays a role in this ecosystem, and adherence to these guidelines is mandatory across the board.

Safeguards

To achieve NOV's mission and the purpose of this cybersecurity policy, the organization shall implement the following controls:

A. Workforce Identity and Screening (HR & HSE)

- ID-01 HR must perform background screening for all workforce members, with enhanced screening for individuals accessing Critical Cyber Assets (CCA) on drilling rigs or manufacturing floors.
- ID-02 Access to offshore or hazardous site systems is conditional upon valid HSE (Health, Safety, Environment) certifications in addition to digital credentials.
- ID-03 Immediate revocation of digital certificates and physical tokens like smart cards upon termination. For field engineers, this includes the immediate remote wiping of mobile devices containing NOV proprietary data.

B. OT and Industrial Access Controls

- ID-04 Strict separation between IT (Corporate) and OT (Industrial) identities. A corporate Active Directory account should not directly authenticate to a drilling control system without an intermediary "jump host" or PAM (Privileged Access Management) solution.
- ID-05 "Operator" accounts on rig HMI screens may be used only if they are restricted to non-administrative tasks and physically secured. Administrative access to these systems must be attributable to a specific individual.
- ID-06 Third-party vendors performing remote maintenance on rigs must use Ephemeral (Time-Based) Accounts that are monitored and automatically disabled after the maintenance window closes.

C. Authentication Standards

- ID-07 Corporate or Cloud: Multi-Factor Authentication (MFA) is mandatory for all access.

Remote or Rig Sites: Where internet connectivity is intermittent, offline MFA tokens such as Yubikey must be used. MFA is strictly required for any remote access into the NOV network.
- ID-08 Passwords for SCADA/ICS systems must never be default. All default vendor credentials must be changed before deployment to the field.

D. Monitoring & Anomaly Detection

- ID-09 The SOC (Security Operations Center) will monitor "Impossible Travel" for example when a user logging in from Houston and a North Sea rig simultaneously to detect compromised credentials.
- ID-10 All access to "Break-Glass" emergency accounts on rigs must be logged and reviewed by the Rig Manager and Cybersecurity team within 24 hours.



Policy Sanctions

Non-compliance with this policy is a violation of the NOV Code of Business Conduct and Ethics. Depending on the severity of the breach, consequences can range from mandatory retraining and formal warnings to the suspension of remote access privileges or, in serious cases, termination of employment and contract. It is important to understand that if a violation involves illegal activity, individuals may also face legal consequences under applicable laws. These strict measures are in place not to be punitive, but to emphasize the critical importance of cybersecurity in safeguarding NOV's digital and physical assets, ensuring that our enforcement is always fair, consistent, and proportional to the risk posed.